

EXECUTIVE REPORT

Penetration Testing Assessment — OPFOR-02 Healthcare CTF

ENTERPRISE RISKS

These are the top most enterprise risk in Healthcare

- Unauthenticated SQL injection on the patient login page. An attacker outside the network could pull the whole patient and user database without needing any password.
- Patient document files store passwords in plain text. If someone gains access to the system, they can view real login data for staff accounts and for patients too.
- The admin healthcheck tool can be misused to grant full control of the server. A basic user account can be turned into a root-level account with full power.
- The root login uses the same value for the username and the password. So the root credentials are effectively root and root.
- If someone reaches a login prompt, the credentials are very easy to guess. Staff accounts use the same value for username and password, like medical/medical and admin/admin. That setup is easy to crack and does not provide real protection.
- The patient records software, OpenEMR, is very old and not supported. Public exploits for it are already known, and they should keep working until an upgrade happens.
- The website stack, including PHP, Apache, and the FTP service, is also old and not supported.

ATTACK-CHAIN SUMMARY

- I checked the target and located a public site plus an FTP service.
- Beneath that, I also noticed a concealed patient records app named OpenEMR.
- On the login page, I spotted a flaw and verified it was SQL injection. It let me pull database content without a password.
- With that same flaw, I pulled the two staff logins and their password data. Then I broke those passwords.
- After I got in, I looked around OpenEMR and found a file with staff usernames and passwords saved in plain text.
- One of those passwords also worked for a standard desktop login on the server. That gave me an entry point into the host.
- I then located an admin utility on the server that was meant to run basic safe checks. A mistake in the tool let me bypass the limits and gain full root access.
- I verified I had root, saved evidence, and then removed what I had changed. I also put the machine back the way it was before.

BUSINESS IMPACT

If this were an actual hospital or clinic system instead of a training setup, the risks would be high.

- Patient files, including names, medical details, and phone or email info, could be read, copied, altered, or removed by someone without permission.
- Staff logins could be hijacked because passwords were kept in plain text and were also easy to guess.

- If an intruder got into the host computer, they could control the full server, not only the patient records app. That could mean taking the site offline, adding harmful software, or using the server to target other systems.
- A real incident could damage patient confidence, trigger legal and regulatory issues, and require expensive cleanup afterward. Health data is typically governed by strict rules.

TOP REMEDIATION PRIORITIES

- Update or rebuild the login page so it validates and filters input correctly. This addresses the SQL injection weakness.
- Remove the plain-text password file and the password PDF from the patient document area. Then change every password that appears in those files.
- Correct the admin health-check tool so it calls system commands with the right full paths. This targets the root takeover problem.
- Replace the root password with a long, random value that does not match the username.
- Reset all staff passwords so none are the same as the username, and enable a password policy.
- Move the patient records system, OpenEMR, to a version that is still supported.
- Update the main website software.